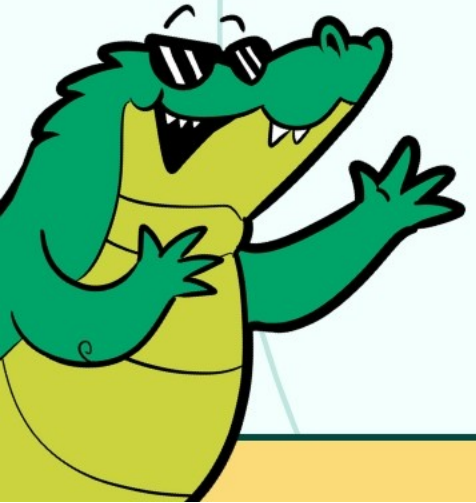
Insecure by Design: Breaking a Consumer IoT Camera's Trust Model



Matthew Dubbrin





The Simpsons ©Disney/20th Television — Image via themirror.com

EARWIG

Insecure by Design: Breaking a Consumer IoT Camera's Trust Model

Matthew Dubbrin - BSides Orlando - 09/26/2026

© 2026 Matthew Dubbrin All Rights Reserved

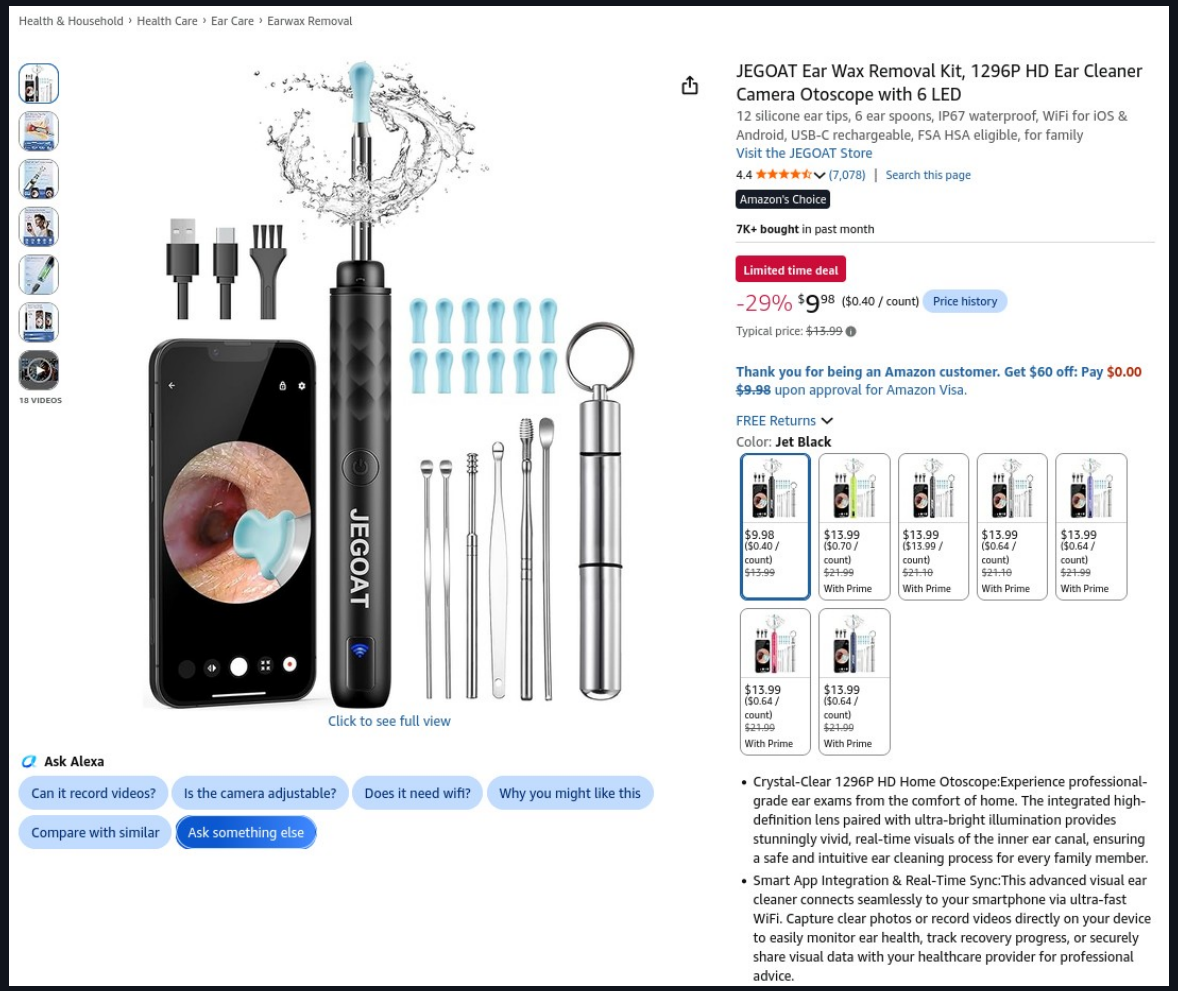
ABOUT ME

whoami

- BS Information Technology and Cybersecurity Minor, University of Central Florida
- Wi-Fi, BLE/Bluetooth Security Research
- IoT Security
- Network Engineering/Security
- Amateur Radio

THE DEVICE

Meet the Target: “JEGOAT Ear Wax Removal Kit”



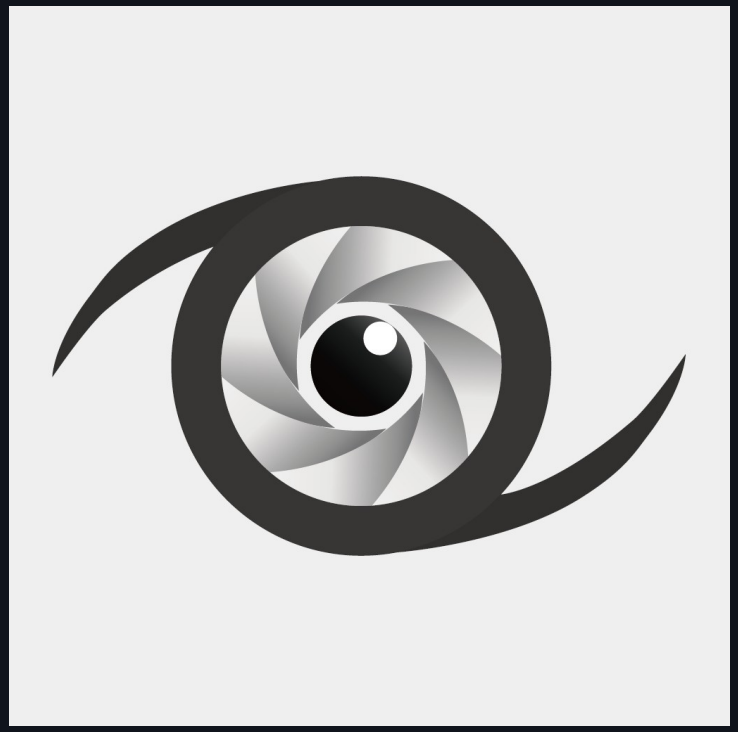
- ~$10-$15
- *“Crystal-Clear 1296P HD Home Otoscope”*
- *Smart App Integration & Real-Time Sync...connects seamlessly to your smartphone via ultra-fast WiFi...”*
- Companion app: EarVision (Apple App Store & Google Play Store)

amazon.com product listing, captured Sept 2026

THE DEVICE

How Popular Is the Device?

- White-label product
- Sold on several sites
- 7,000+ reviews on Amazon alone
- 500K+ companion app downloads (Google Play Store)



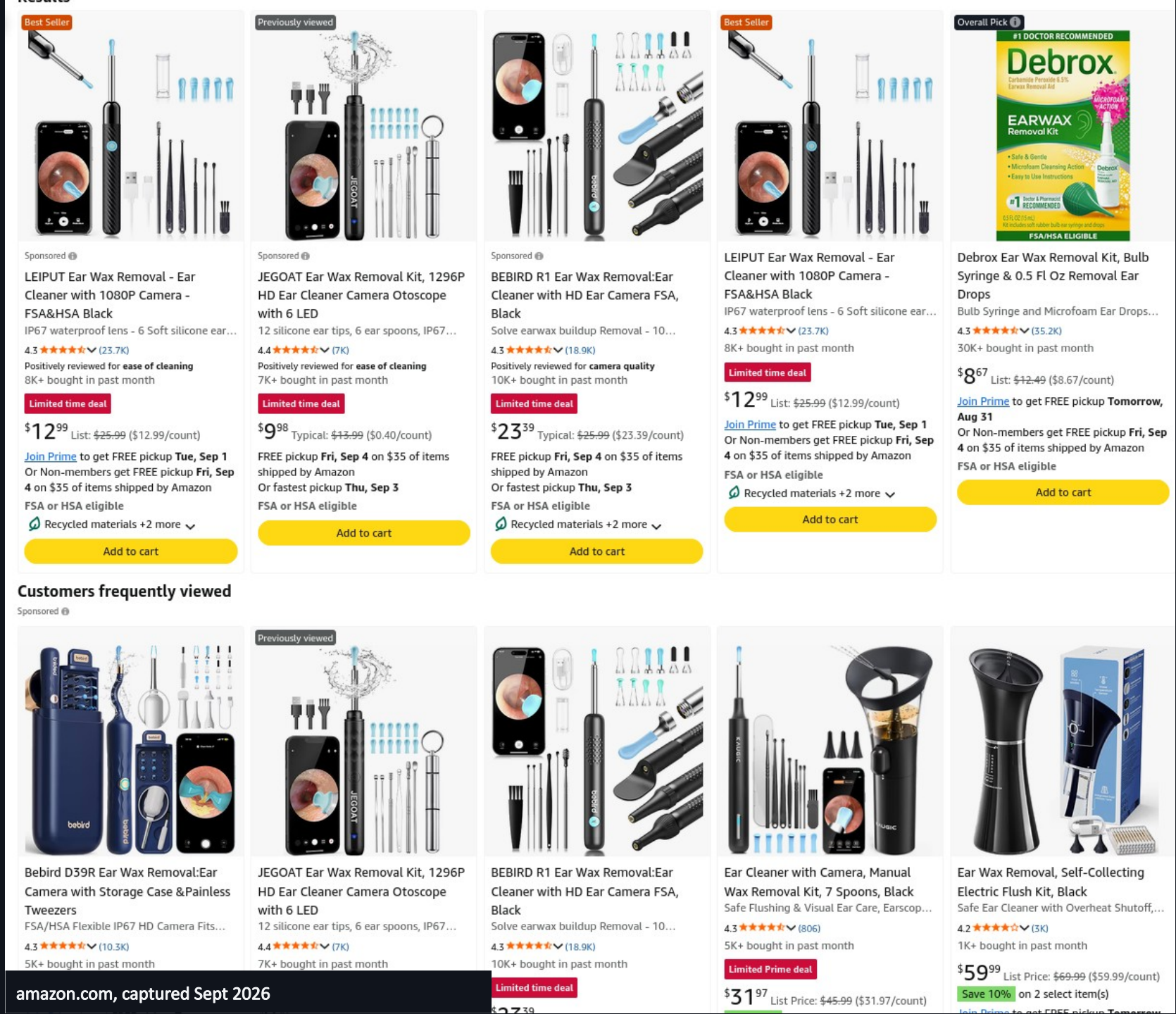
THE DEVICE

Amazon.com

~38,000+

Bought in

August



amazon.com, captured Sept 2026

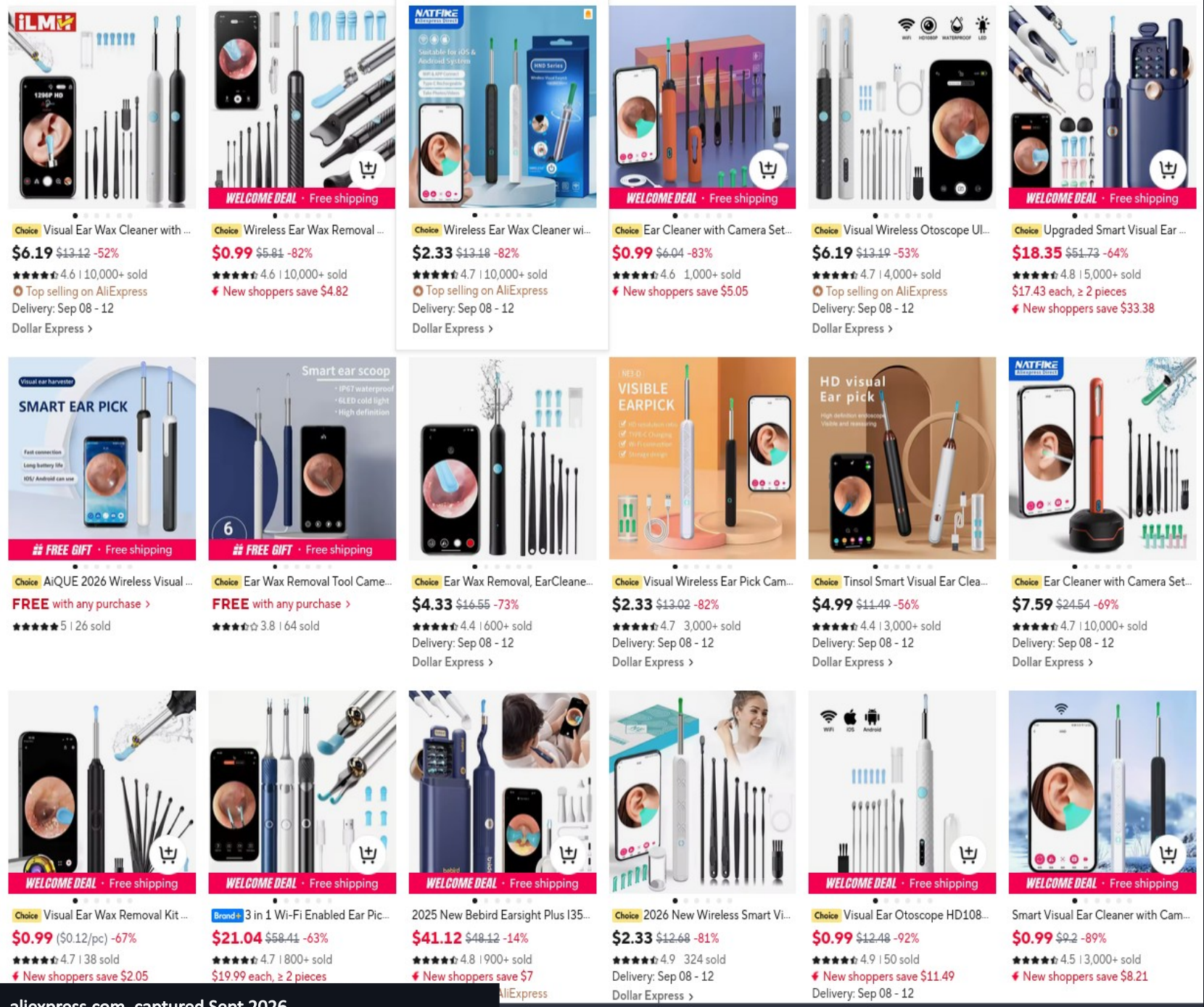
THE DEVICE

AliExpress.com

~56,000+

Bought in

August



aliexpress.com, captured Sept 2026

FROM EARVISION'S OWN PRIVACY POLICY, BUNDLED IN THE APP

“We take your personal information security very seriously.”

“We promise to make every effort to protect the security of your personal information.”

Tools used

- **Jadx:** APK manifest decoding

- **airmon-ng / airodump-ng / aircrack-ng:** monitor-mode capture, beacon/handshake dump, and WPA password cracking

- **Scapy:** packet crafting and protocol probing

- **Wireshark:** live capture, packet filtering, and stream export

RECON & PROTOCOL REVERSE ENGINEERING

BLE + Wi-Fi discovery flow



Two independent identity signals, checked once, trusted forever for that session.

Findings

FINDING 1 - CVE-2026-81640

Wi-Fi Password Derivation

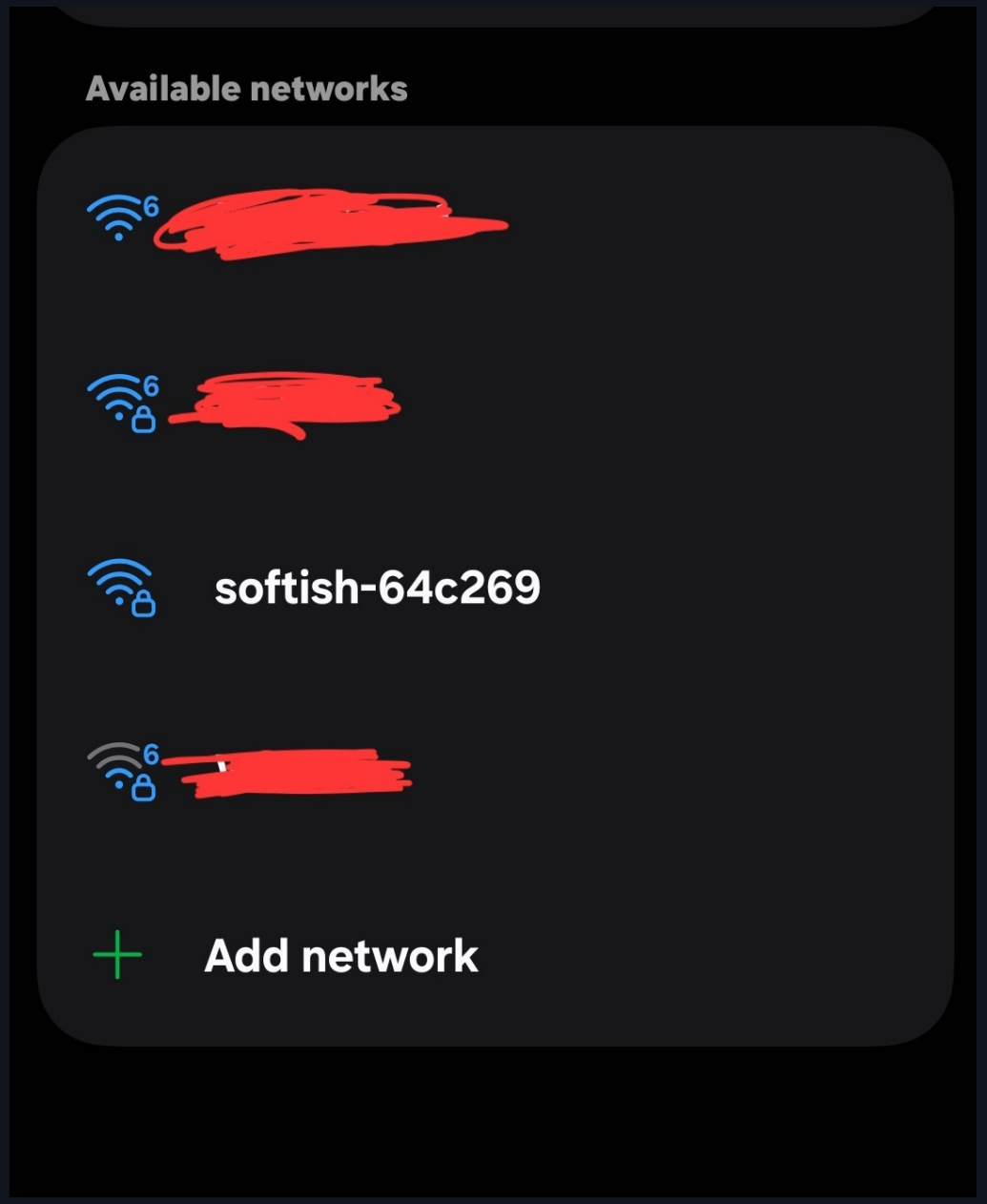
CWE-798 - CVSS 8.8

- AP password is computed using the BSSID, which is broadcast in plaintext in every 802.11 beacon frame
- **No association needed to derive the credential**

148	0.218452060	86:18:75:69:c2:64	REDACTED	802.11	704	QoS Data, SN=2604, FN=0, Flags=.pm...F.
149	0.244261926	86:18:75:69:c2:64		802.11	1324	QoS Data, SN=2605, FN=0, Flags=.pm...F.

FINDING 1 - IMPACT

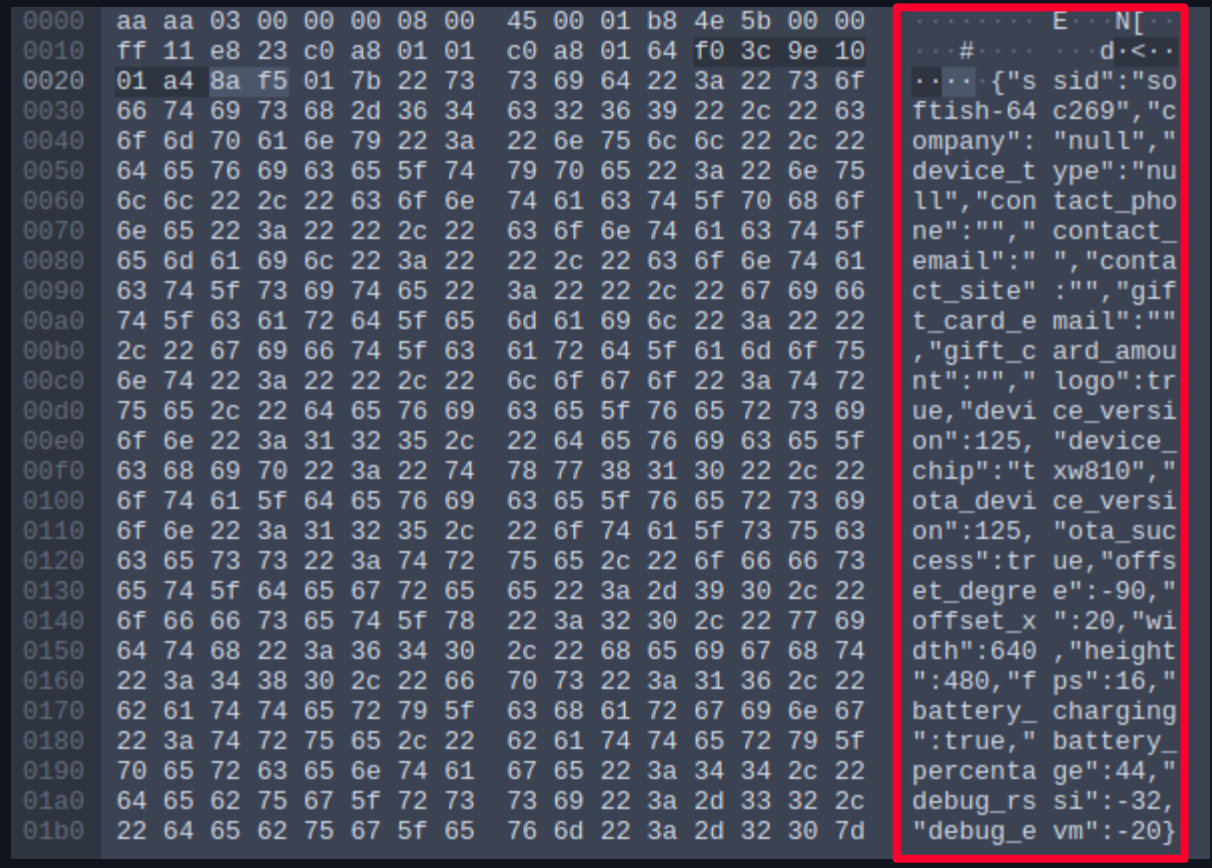
- Secret is broadcast in the clear
- Sets up next vulnerabilities



IMPORTANT NOTE

The JSON Status Response


```
{
  "ssid": "softish-64c269",  "company": "null",
  "device_type": "null", "contact_phone": "",
  "contact_email": "", "contact_site": "", "gift_card_email":
  "", "gift_card_amount": "",  "logo": true,
  "device_version": 125, "device_chip": "txw810",
  "ota_device_version": 125,  "ota_success": false,
  "offset_degree": -90, "offset_x": 20, "width": 640,
  "height": 480, "fps": 16, "battery_charging": true,
  "battery_percentage": 86, "debug_rssi": -29,
  "debug_evm": -24
}
```

FINDING 2 - CVE-2026-82563

Device Spoofing via Rogue Access Point

CWE-290 - CVSS 7.6

- The app checks: SSID string and BLE advertisement identity.
- That's the entire identity check no certificate, no challenge-response, no mutual authentication.

FINDING 2 - CONTINUED

Device Spoofing via Rogue Access Point

JSON Headers


```
{
  "ssid": "softish-64c269", "company": "null", "device_type": "null", "contact_phone": "",
  "contact_email": "", "contact_site": "", "gift_card_email": "", "gift_card_amount": "",
  "logo": true, "device_version": 125, "device_chip": "txw810", "ota_device_version": 125,
  "ota_success": false, "offset_degree": -90, "offset_x": 20, "width": 640, "height": 480,
  "fps": 16, "battery_charging": true, "battery_percentage": 86, "debug_rssi": -29,
  "debug_evm": -24
}
```

FINDING 2 - DEMO

Custom ESP32 firmware

Which one is the real camera?

Replicates the BLE advertisement - hosts the matching Wi-Fi AP identity



EarVision app v1.3.1, screen capture

Accepted, no questions asked.

The app connects and accepts a forged status response — no authentication required.

Full MitM position. Every JSON status field, every UDP response, now under attacker control.

FINDING 3 - CVE-2026-77974

Unauthenticated OTA Firmware Push

CWE-306 - CVSS 8.0

JSON Headers


```
{
  "ssid": "softish-64c269",  "company": "null", "device_type": "null", "contact_phone": "",
  "contact_email": "", "contact_site": "", "gift_card_email": "", "gift_card_amount": "",
  "logo": true, "device_version": 125, "device_chip": "txw810", "ota_device_version": 125,
  "ota_success": false, "offset_degree": -90, "offset_x": 20, "width": 640, "height": 480,
  "fps": 16, "battery_charging": true, "battery_percentage": 86, "debug_rssi": -29,
  "debug_evm": -24
}
```

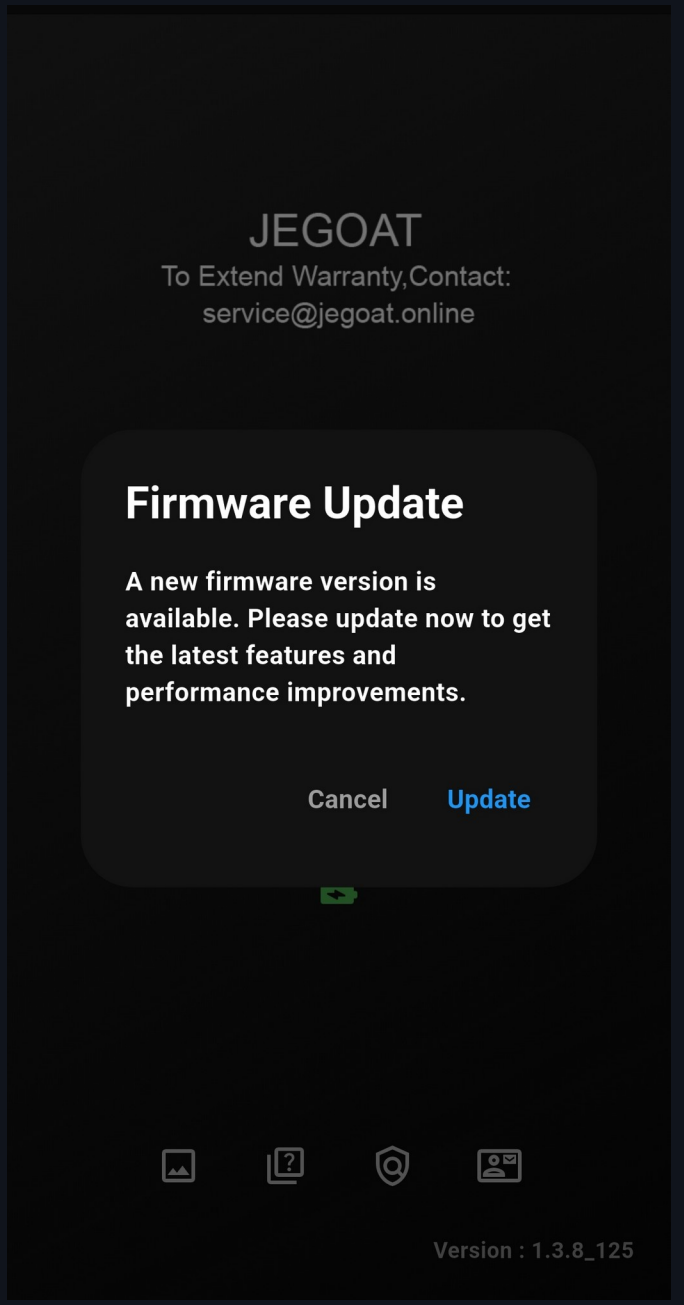
FINDING 3 - CONTINUED

Unauthenticated OTA Firmware Push

Triggers the update prompt:

```
ota_device_version > device_version*
```

*modified in spoof code



EarVision app v1.3.1, screen capture during testing

FINDING 3 - CONTINUED

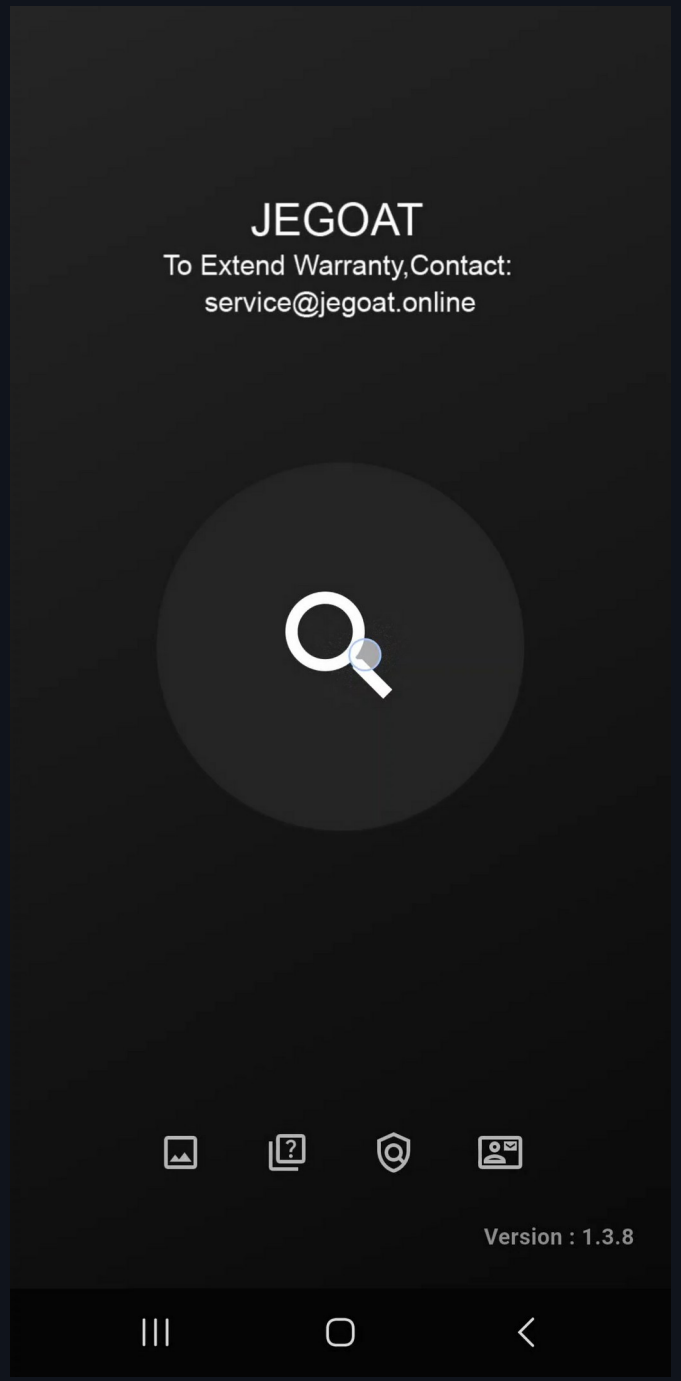
Byte-for-byte + disabled integrity

```
10 04 payload:  @0x10:  69 5A 00 1C 00 00 00 18 00 00 00 18 00 0C
00 00
txw810_125.bin: @0x00:  69 5A 00 1C 00 00 00 18 00 00 00 18 00 0C
00 00
```

code_crc32 = 0x00000000 head_crc16 = 0x0000

Integrity checking isn't broken. It's turned off.

FINDING 3 - DEMO



Pushed using the rogue-AP MitM position established in Finding 2

FINDING 4 - CVE-2026-81330

Unencrypted Video Stream

CWE-319

`android:usesCleartextTraffic="true"`

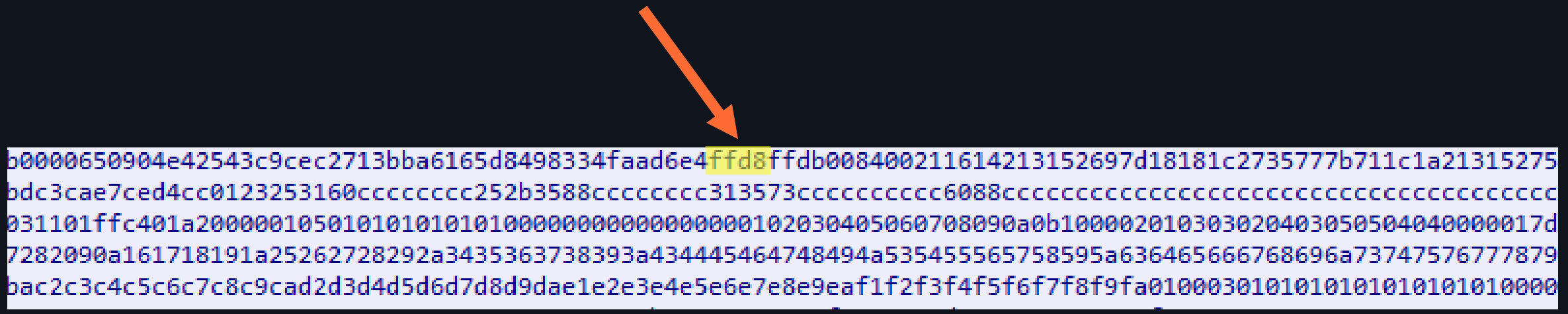
- UDP 61501: raw JPEG
- UDP 61500: control JSON

9256	21.849421601	192.168.1.1	192.168.1.100	UDP	1324	61501 → 41050 Len=1228
9258	21.849898537	192.168.1.1	192.168.1.100	UDP	1324	61501 → 41050 Len=1228
9259	21.850146697	192.168.1.1	192.168.1.100	UDP	1324	61501 → 41050 Len=1228
9260	21.851195247	192.168.1.1	192.168.1.100	UDP	1324	61501 → 41050 Len=1228
9262	21.851634273	192.168.1.1	192.168.1.100	UDP	1324	61501 → 41050 Len=1228

FINDING 4 - CONTINUED

Unencrypted Video Stream

- The issue: a single UDP packet can’t hold the entire JPEG (only 1400 bytes)
- Packet 1 holds bytes 0-1400 , packet 2 holds bytes 1401-2800, etc



FINDING 4 - CONTINUED

Unencrypted Video Stream

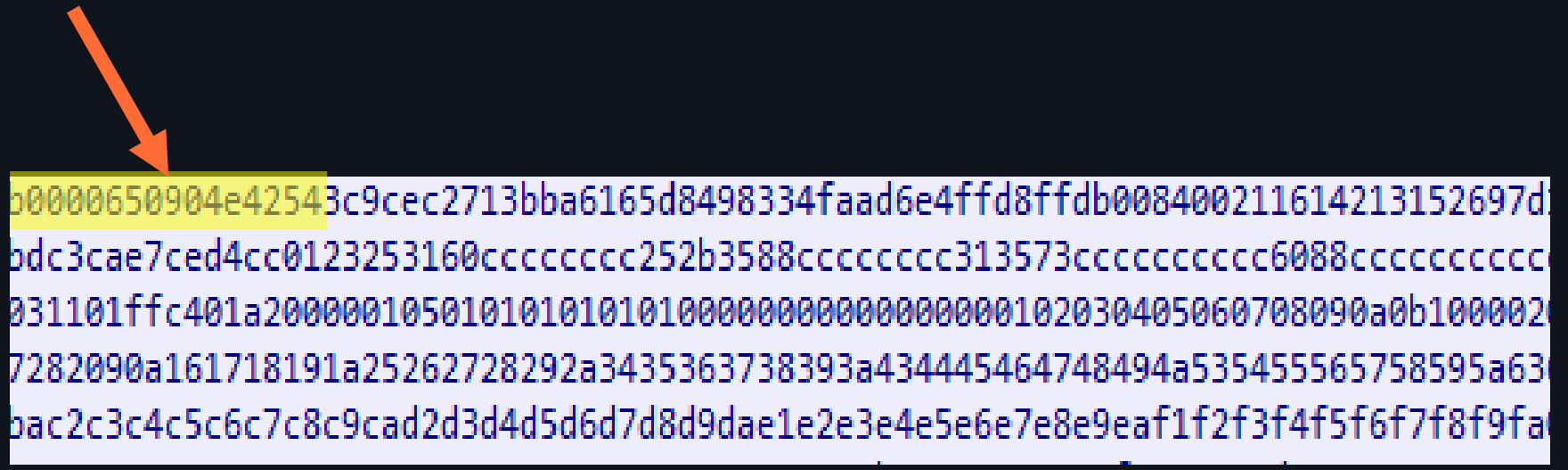
- 1: Filter packets for the correct port and BSSID *
- 2: Follow the UDP Stream
- 3: Export the filtered packets' dissections as raw binary (File → Export Packet Dissections → As raw...)

*Wireshark filter: wlan.bssid==86:18:75:69:C2:64 && udp.srcport == 61501

FINDING 4 - CONTINUED

Unencrypted Video Stream

- 4: Determine the per-packet header size (byte offset of \xff\xd8 in the first payload)



FINDING 4 - CONTINUED

Unencrypted Video Stream

- 5: Strip the first 8 bytes (the header) from each payload, splice what remains onto the end of the previous packet's remainder, walking through the packets in order until the whole stream is stitched back together
- 6: Scan the stream for \xff\xd8 / and \xff\xd9 marker pairs to slice out individual JPEG frames
- 7: Write each frame out as a .jpg

FINDING 4 - PROOF



Anyone within Wi-Fi range.

No pairing. No login. No association required.

THE CHAIN

1 → 2 → 3



Zero physical access. Under $5 of hardware. One human action.

CASE STUDY - OUR OWN RESEARCH

WiZ Smart Bulbs

- Local control over UDP port 38899, plaintext JSON, zero authentication
- Not “misconfigured”. It is the intended design of the local control API

One line. No authentication

```
python3 -c "
import socket,json; socket.socket(socket.AF_INET,
socket.SOCK_DGRAM).sendto(json.dumps({'method':'setPilot','params':
{'state':True}}).encode(), ('BULB_IP', 38899))"
```

That's the entire exploit. No credentials. No pairing. One UDP packet.

THE PATTERN - CHEAP TIER

This repeats — cheap devices

- **Mirai (2016)**
  — hardcoded default credentials on cameras/DVRs → 500,000+ device botnet, took down Dyn DNS
- **TP-Link / D-Link routers (2024–2026)**
  — unauthenticated firmware upload, hardcoded Telnet credentials
- **Arlo cameras**
  — predictable default Wi-Fi passwords after setup/reset — closest direct analog to Finding 3

THE PATTERN - EXPENSIVE TIER

This repeats — expensive devices

- **Verkada (2021)**

  — hardcoded super-admin credential → 150,000+ enterprise cameras compromised

- **St. Jude/Abbott pacemakers (2017)**

  — first-ever FDA cybersecurity recall, weak RF device authentication, ~465,000 devices vulnerable to rapid battery depletion or altered pacing controls

- **Hospira infusion pumps (2015)**

  — unauthenticated, unsigned firmware updates on a drug-dosing device

- **Jeep Cherokee (2015)**

  — unauthenticated remote command channel, allowing attackers to interact with physical actuators→ 1.4M vehicle recall

Same failure classes. Zero to seven figures in device cost.

What actually works

- **NIST IR 8259A**

  — baseline regulations: device identification, secure config, signed update mechanism, access control, logging

- **US Cyber Trust Mark (NIST IR 8425 / FCC, 2024)**

  — certifies unique per-device credentials, signed firmware, disclosed support period

- **CISA**

  — procurement-stage risk questions for organizations buying IoT at scale

None of these are exotic. All four EARWIG findings are things these frameworks explicitly ask for.

RECAP

Four findings, one chain, $5of hardware, and one tap, on a device that isn't unique.

Unencrypted stream · spoofable identity · derivable password · unauthenticated OTA — repeated across a $12 bulb, health monitors, a 150,000-camera enterprise fleet, and an implanted pacemaker.

IN THEIR OWN WORDS, REVISITED

~~"We take your personal information security very seriously."~~

~~"We promise to make every effort to protect the security of your personal information."~~

SOURCES

References

EARWIG Findings

CVE-2026-81330

CVE-2026-82563

CVE-2026-81640

CVE-2026-77974

Beyond the Ear Camera

Krebs on Security: "Source Code for IoT Botnet Mirai Released" (2016)

SecurityAffairs: TP-Link Archer NX firmware takeover, CVE-2025-15517

BleepingComputer: D-Link Wi-Fi 6 router hardcoded passwords

Arlo Support: Wi-Fi default password security advisory

IPVM:Verkada hack report (2021)

SecurityWeek: St. Jude Medical pacemaker recall (2017)

CISA ICSA-15-125-01: Hospira infusion pump advisory

Kaspersky: "Black Hat: Jeep Cherokee Hack Explained"

NIST: IR 8259A Federal Profile

FCC: US Cyber Trust Mark (NIST IR 8425)

CISA: IoT Acquisition Guidance

Thank you.

Matthew Dubbrin - mdubbrin@hackucf.org

mdubbrin.github.io

Questions?



BACKUP

CVE / CVSS reference

#	Finding	CVE	CWE	v3.1	v4.0
1	Unencrypted Video Stream	CVE-2026-81330	CWE-319	6.5	7.1
2	Device Spoofing via Rogue AP	CVE-2026-82563	CWE-290	7.6	8.4
3	Wi-Fi Password Derivable	CVE-2026-81640	CWE-798	8.8	8.7
4	Unauthenticated OTA Push	CVE-2026-77974	CWE-306	8.0	8.5